Laporan Fase 1 — Hardening Awal & Baseline Traffic Normal

Mata kuliah: TEK1314 Keamanan Siber (D4 Teknologi Rekayasa Komputer, SV IPB)

Kelas / Kelompok: TEK-A / Kelompok 4

Periode Fase 1: Minggu 1–7 (penyelesaian lab dan dokumentasi: 20–21 Oktober 2026)

Repositori: github.com/anggi267/TEK1314-2026-Kel04-KelasA

Peran	Nama	NIM
Lead	Olan	(lihat lampiran)
Blue Team	Anggi Permana Putra	J0404241154
Red Team	Raka Syauqi Ferdian	J0404241112
Red Team	Zidan	(lihat lampiran)

Ringkasan Eksekutif

Fase 1 membangun fondasi proyek SOC Engagement: tiga node lab pada segmen `192.168.4.0/24` (Attacker Kali, Target Ubuntu Server, Monitoring Security Onion), replika backend IoT yang sengaja memiliki kelemahan terkontrol, hardening awal, dan baseline traffic normal sebagai pembanding deteksi di Fase 2.

Hasil utama:

1. Target Node berjalan **Ubuntu Server 26.04.1 LTS** (dipasang unattended) dengan replika backend IoT: Nginx + PHP-FPM, MariaDB (`iot_db`), Mosquitto, dashboard dan API.
2. **Keenam arah ping** antar tiga node berhasil dengan 0% packet loss, dan sensor Security Onion terbukti merekam trafik lab (promiscuous bekerja).
3. **Hardening awal** diterapkan: patch paket, minimalisasi service, firewall `ufw` (default-deny), dan `fail2ban` — tanpa memutus layanan (dashboard tetap HTTP 200).
4. **Baseline traffic normal** terekam: 440 paket dalam 41,3 detik, tersimpan sebagai `baseline_minggu9.pcap`.
5. Kelemahan yang menjadi sasaran Fase 2 (kredensial lemah, SQL injection, MQTT tanpa autentikasi) **sengaja dipertahankan** dan didokumentasikan agar siklus Purple Team punya sasaran nyata.

---

1. Konteks dan Tujuan Fase 1

Panduan PBL menetapkan Fase 1 (sampai Minggu ke-7) sebagai tahap **hardening awal dan dokumentasi baseline traffic normal**, dengan prinsip "infrastruktur baru dibangun — pastikan baseline aman sebelum go-live".

Tujuan teknis yang ditetapkan kelompok:

6. Menyediakan laboratorium tertutup tiga node sesuai skenario SOC, tanpa koneksi ke sistem Mitra.
7. Membangun replika backend IoT yang mewakili komponen nyata (dashboard, API, basis data, protokol MQTT).

8. Menerapkan kontrol keamanan dasar yang tidak menutup celah yang sengaja dipakai untuk latihan serangan Fase 2.
9. Merekam traffic normal sebagai pembanding (baseline) sebelum ada aktivitas penyerangan.
10. Menyimpan seluruh bukti (konfigurasi, keluaran perintah, pcap) di repositori.

---

2. Arsitektur dan Pengalamatan

2.1 Tiga node

Node	VM VirtualBox	OS	Segmen lab	Adapter kedua
Attacker	`PBL-K4-02-Attacker-Kali`	Kali Linux 2026.2	`192.168.4.100/24`	NAT
Target	`PBL-K4-01-Target-Ubuntu`	Ubuntu Server 26.04.1 LTS	`192.168.4.5/24`	NAT (port-forward 2222→22)
Monitoring	`PBL-K4-03-Monitoring-Onion`	Security Onion 2.x (Ubuntu 16.04)	`192.168.4.200/24`	Host-only 192.168.56.1

Segmen lab memakai **Internal Network** VirtualBox bernama `pbl-kel4`: tidak ada DHCP, tidak ada rute ke internet, sehingga seluruh uji terisolasi. Adapter kedua hanya dipakai untuk pembaruan paket dan akses administrasi.

2.2 Mengapa target memakai Ubuntu Server

Keputusan Minggu 4 semula menetapkan Metasploitable2. Pada pelaksanaan, kelompok mengganti target ke Ubuntu Server karena tiga alasan yang dapat dipertanggungjawabkan:

11. Replika menjadi menyerupai backend IoT sesungguhnya (Nginx, MariaDB, Mosquitto), bukan kumpulan layanan acak.
12. `apt`, `ufw`, `fail2ban`, dan `systemctl` berfungsi normal, sehingga kontrol hardening dapat dibuktikan before/after. Basis Metasploitable2 (Ubuntu 8.04) sudah EOL dan repositorinya tertutup.
13. Kelemahan dapat dirancang eksplisit dan masing-masing punya kontrol penutup yang akan diuji pada Fase 2.

Diagram terbaru: `docs/design/topology-v2.png`. Alokasi IP tidak berubah dari Minggu 4.

---

3. Penyediaan Laboratorium

3.1 Konfigurasi host (VirtualBox)

Nama VM diseragamkan menjadi `PBL-K4-0X-Peran-OS` dan diberi deskripsi peran serta IP agar tidak tertukar. Seluruh adapter pertama dipindahkan ke Internal Network `pbl-kel4`; adapter sensor diberi promiscuous `allow-all`. Audio dimatikan, vCPU diset 2, dan snapshot dasar dibuat pada ketiga VM.

3.2 Instalasi target secara unattended

Target dipasang menggunakan mekanisme **autoinstall** Ubuntu Server dengan seed cloud-init NoCloud (volume berlabel `CIDATA`), berisi: hostname `target-iot`, user `iotadmin`, server SSH, zona waktu Asia/Jakarta, dan `shutdown: poweroff` setelah selesai.

Beberapa kendala instalasi yang ditemukan dan solusinya:

Gejala	Penyebab	Solusi
Boot berhenti di "Loading essential drivers"	floppy controller aktif tanpa media	`--floppy disabled`
Installer lama tanpa menulis disk	menunggu jawaban `Continue with autoinstall?`	jawab `yes` pada konsol
DVD tidak bootable setelah pindah controller	posisi ISO berubah saat port SATA diubah	ISO installer di IDE 0-1, seed di IDE 1-0
Proses menggantung di `wait_for_apply`	NIC lab tanpa DHCP	NIC lab dinonaktifkan sementara saat instalasi
Ekstraksi image macet	disk dinamis + RAM 3 GB	disk fixed 25 GB + RAM 4 GB

Hasil verifikasi guest: `Ubuntu 26.04.1 LTS`, kernel `7.0.0-38-generic`, hostname `target-iot`, user `iotadmin` (anggota grup sudo), sshd OpenSSH 10.2p1, disk 25 GB terpakai 7,4 GB.

3.3 Akses administrasi

Sudo tanpa password untuk `iotadmin` diaktifkan agar proses otomasi berjalan (keputusan operasional laboratorium; dicatat sebagai hal yang harus dicabut sebelum penilaian akhir). Sudo ini diset melalui root shell GRUB (`init=/bin/bash`) karena `cloud-init` pada sistem hasil autoinstall berstatus *disabled*.

---

4. Replika Backend IoT

4.1 Stack yang terpasang di Target Node

Komponen	Perangkat lunak	Versi	Port	Keterangan
Web server / dashboard	Nginx	1.28.3	80	menyajikan `index.php`, `login.php`
Application runtime	PHP-FPM	8.5.4	—	socket `php8.5-fpm.sock`
Basis data	MariaDB	11.8.6	3306	hanya `127.0.0.1`, database `iot_db`
Broker MQTT	Mosquitto	2.x	1883	`allow_anonymous true` (kelemahan disengaja)
Manajemen	OpenSSH	10.2p1	22	password auth aktif (kelemahan disengaja)

4.2 Skema data

Tabel `users` (id, username, password, role) dan `sensor_readings` (id, moisture, ts) dengan data contoh lima pembacaan kelembapan. Endpoint yang tersedia:

- `GET /` — dashboard menampilkan lima pembacaan terakhir.
- `GET /login.php` — formulir login operator.
- `GET /api.php?id=N` — API data sensor dalam JSON.

4.3 Kelemahan yang sengaja dipertahankan (sasaran Fase 2)

#	Kelemahan	Lokasi	Skenario	Ditutup pada Fase 2 oleh
1	Kredensial lemah `iotadmin/123` + password auth aktif	22	RT-02	A-1, A-2, A-4, B-3
2	SQL injection pada `api.php` dan `login.php`	80	RT-03	C-2, C-3

3	MQTT anonim tanpa ACL	1883	RT-04	C-2
4	Layar dashboard tanpa TLS	80	RT-03	(temuan, dicatat)
5	Service tidak terpakai masih aktif	lokal	RT-01	B-1
6	Tanpa rate limit pada HTTP	80	RT-05	ufw limit

Pemisahan ini disengaja: Fase 1 hanya mengerjakan kontrol yang **tidak menghilangkan** sasaran serangan, sedangkan kontrol yang menutup celah tersebut dikerjakan pada siklus Purple Team Fase 2 sehingga bukti before/after-nya nyata.

---

5. Hardening Awal (Fase 1)

5.1 Kontrol yang diterapkan

Kontrol	Tindakan	Bukti
Patch sistem	`apt-get update` + `upgrade` + `full-upgrade`	`before.txt`/`after.txt` (15 paket tersisa ditahan *phased update* Ubuntu)
Minimalisasi service	menonaktifkan `ModemManager`; service lain (avahi, cups, rpcbind, bluetooth) tidak terpasang pada instalasi minimal	daftar service `after.txt`
Firewall	`ufw` default **deny incoming**, allow 22/tcp, 80/tcp, 1883/tcp hanya dari `192.168.4.0/24`	`sudo ufw status verbose`
Pembatasan basis data	MariaDB hanya mendengarkan `127.0.0.1:3306`	`ss -tulpn`
Proteksi brute force	`fail2ban` aktif dengan jail `sshd`	`fail2ban-client status sshd`
Logging	`rsyslog` aktif; `ufw` logging level low	daftar service

5.2 Status port setelah hardening

```
tcp LISTEN 0 80    127.0.0.1:3306     (MariaDB, lokal)
tcp LISTEN 0 100   0.0.0.0:1883       (Mosquitto)
tcp LISTEN 0 4096  127.0.0.53%lo:53   (systemd-resolved, lokal)
tcp LISTEN 0 4096  0.0.0.0:22         (SSH)
tcp LISTEN 0 511   0.0.0.0:80         (Nginx)
```

Empat port yang benar-benar terbuka ke segmen lab: 22, 80, 1883 (dibatasi firewall), dan 3306 yang hanya lokal pada host.

5.3 Uji bahwa hardening tidak memutus layanan

Dari Attacker Node:

```
HTTP=200
[{"id":3,"moisture":44,"ts":"2026-10-21 16:55:30"}]
```

Dashboard tetap dapat diakses dan API mengembalikan JSON yang valid setelah `ufw` diaktifkan.

5.4 Kontrol yang sengaja BELUM dikerjakan

Kontrol A-2 (key-based SSH), A-3 (ganti port), C-2 (prepared statement), C-3 (least privilege), dan B-3 (hapus kredensial default) **belum** dikerjakan pada Fase 1 karena akan menghilangkan sasaran skenario RT-02/RT-03. Kontrol tersebut dijadwalkan pada Fase 2 dengan bukti before/after di `docs/blueteam/hardening_checklist.md`.

---

6. Baseline Traffic Normal

6.1 Cara pengambilan

Capture dilakukan pada interface lab Target Node (`enp0s3`) sambil membangkitkan traffic normal dari Attacker Node selama 100 detik: ping ICMP periodik, permintaan dashboard (`/`), dan permintaan API (`/api.php?id=N`) setiap dua detik.

```
sudo tcpdump -i enp0s3 -nn -w /tmp/base2.pcap -c 800
```

6.2 Metrik baseline

Metrik	Nilai
Total paket	440
Durasi capture	41,3 detik (17:05:07 – 17:05:48)
Paket ICMP	40 (ping 1 paket per iterasi)
Paket TCP	400
Paket yang menyentuh port 80	240 (handshake + request/response HTTP)
Sumber paket	`192.168.4.100` = 260 paket, `192.168.4.5` = 180 paket
Ukuran file pcap	58.624 byte

Contoh paket pembuka koneksi HTTP:

```
17:05:07.656376 IP 192.168.4.100.34884 > 192.168.4.5.80: Flags [S], seq 2236195093, win 64240
17:05:07.656456 IP 192.168.4.5.80 > 192.168.4.100.34884: Flags [S.], seq 2758904524, ack 2236195094
```

6.3 Artefak

- `docs/blueteam/evidence/baseline/baseline_minggu9.pcap`
- `docs/blueteam/evidence/baseline/baseline_metrics.txt`
- Ringkasan tabel di bagian ini.

Baseline ini menjadi pembanding saat Fase 2: lonjakan koneksi, pola scan, atau request HTTP berulang dapat dinilai menyimpang atau tidak terhadap angka di atas.

---

7. Verifikasi Keterhubungan

Dari \ Ke	Target `192.168.4.5`	Kali `192.168.4.100`	Onion `192.168.4.200`
Target	—	0% (3,3 ms)	0% (3,9 ms)
Kali	0% (7,5 ms)	—	0% (2,2 ms)
Onion	0% (4/4 paket terekam)	0% (2,0 ms)	—

Bukti sensor melihat trafik lab (`tcpdump -i eth0` di Onion):

```
16:04:03.136797 IP 192.168.4.100 > 192.168.4.5: ICMP echo request, id 58782, seq 1
16:04:03.137413 IP 192.168.4.5 > 192.168.4.100: ICMP echo reply, id 58782, seq 1
```

Dua kendala jaringan yang ditemukan dan diselesaikan:

14. IP yang ditambahkan dengan `ip addr add` pada interface yang dikelola NetworkManager (Kali) tidak dijawab ARP → host lain gagal ping. Solusi: profil `nmcli` bernama `pbl-lab`.

15. Interface sensor Security Onion dikonfigurasi `promisc on arp off` (desain sniffing pasif), sehingga IP `.200` tidak menjawab ARP. Solusi: `arp on` (runtime dan permanen) serta `post-up ip addr add 192.168.4.200/24 dev eth0`.

---

8. Kendala dan Pembelajaran

#	Kendala	Pembelajaran

1	VM tidak saling terhubung karena adapter berbeda segmen	Topologi harus diverifikasi di level hypervisor, bukan hanya di diagram
2	Instalasi unattended berhenti pada konfirmasi	Otomasi tetap butuh titik konfirmasi; konsol harus dipantau
3	`cloud-init` disabled pada sistem hasil autoinstall	Jangan mengandalkan cloud-init pasca-instalasi; siapkan jalur akses alternatif
4	ARP gagal pada IP statis di Kali	Kelola IP lewat NetworkManager, jangan `ip addr add`
5	IP sensor tidak menjawab ARP	Pahami mode kerja sensor (pasif, `arp off`) sebelum menaruh IP
6	Paket upgrade tertahan	Sebagian pembaruan ditahan *phased update*; dicatat sebagai sisa pekerjaan B-3

9. Kesimpulan dan Kesiapan Fase 2

Fase 1 selesai secara teknis: laboratorium tiga node berjalan, replika backend IoT tersedia dan dapat diakses, hardening awal terbukti tidak memutus layanan, serta baseline traffic normal terdokumentasi lengkap dengan pcap dan metrik.

Kesiapan menuju Fase 2:

16. Sasaran serangan sudah tersedia dan terdaftar (enam kelemahan sengaja) beserta kontrol penutupnya.
17. Sensor Security Onion terbukti menerima trafik segmen lab, sehingga deteksi dapat diuji.
18. Baseline angka tersedia, sehingga anomali dapat dinilai secara kuantitatif.
19. Sisa pekerjaan yang harus diselesaikan di awal Fase 2: verifikasi `so-status` (SO 2.x EOL), pencabutan sudo NOPASSWD sebelum penilaian, dan pelaksanaan 10 kontrol hardening penuh dengan bukti before/after.

Lampiran A — Artefak di repositori

Artefak	Lokasi
Diagram topologi (revisi)	`docs/design/topology-v2.png`
Skema IP + catatan revisi	`docs/design/ip_plan.md`
Panduan replika & kelemahan sengaja	`docs/design/replica_setup.md`
Catatan konfigurasi VM	`docs/design/vm_config.md`
Status lab & progres	`docs/lab-status.md`
Bukti hardening awal	`docs/blueteam/evidence/hardening-fase1/before.txt`, `after.txt`
Baseline pcap + metrik	`docs/blueteam/evidence/baseline/`
Checklist hardening (rencana penuh)	`docs/blueteam/hardening_checklist.md`
Rencana serangan Fase 2	`docs/redteam/attack_plan.md`

Lampiran B — Perintah verifikasi ulang

```
# dari host: nyalakan tiga node lalu uji target
VBM="/c/Program Files/Oracle/VirtualBox/VBoxManage.exe"
"$VBM" startvm "PBL-K4-01-Target-Ubuntu" --type headless
ssh -p 2222 iotadmin@127.0.0.1              # password: 123

# di target
sudo ufw status verbose
sudo fail2ban-client status sshd
curl -s http://127.0.0.1/api.php?id=1
ping -c 2 192.168.4.100 && ping -c 2 192.168.4.200
```

```
# di sensor (konsol)
sudo tcpdump -i eth0 -nn host 192.168.4.100
```